

SAP SECURITY ADMINISTRATION, OPERATIONS & TROUBLESHOOTING

Chapter 4 – SAP Audit, Compliance, Logging & Monitoring

Q231. What is the SAP Security Audit Log?

Interviewer's Objective

The interviewer wants to determine whether you understand the Security Audit Log as an enterprise monitoring control rather than just another SAP log.

Executive Answer

The SAP Security Audit Log records security-related events occurring within an SAP system.

It enables organizations to monitor, investigate, and report on security events for audit, compliance, and forensic purposes.

Typical events include:

- User logon attempts
- Failed logons
- User creation
- User deletion
- Role assignments
- Authorization failures
- RFC logons
- Transaction execution
- Critical administrative actions

The Security Audit Log supports compliance with frameworks such as SOX, ITGC, ISO 27001, and internal security policies.

Business Benefits

- Detect unauthorized activities
- Investigate security incidents

- **Support audits**
 - **Maintain forensic evidence**
 - **Improve compliance**
-

Q232. Explain SM19 and SM20.

One of the most common interview questions.

SM19

Configuration transaction.

Used to define:

- **What events to audit**
- **Which users to monitor**
- **Which clients to monitor**
- **Log destinations**
- **Filters**

Think of SM19 as:

Audit Configuration

SM20

Reporting transaction.

Used to:

- **View audit logs**
- **Search events**
- **Filter activities**
- **Investigate incidents**
- **Export audit evidence**

Think of SM20 as:

Audit Investigation

Simple Comparison

Transaction Purpose

SM19 Configure Audit Logging

SM20 Review Audit Logs

Q233. What events should be audited?

Executive Answer

Typical events include:

Authentication

- **Successful logons**
 - **Failed logons**
 - **Password changes**
-

User Administration

- **User creation**
 - **User deletion**
 - **User lock/unlock**
 - **Password reset**
-

Authorization

- **Failed authorization checks**
 - **Critical role assignments**
 - **SAP_ALL assignment**
-

Technical Activities

- **RFC logons**
 - **Background jobs**
 - **Trusted RFC changes**
 - **Gateway events**
-

Administrative Activities

- **Profile changes**
 - **Client changes**
 - **Transport administration**
 - **System parameter changes**
-

Q234. Explain SUIM.

Very common interview question.

Executive Answer

SUIM (User Information System) provides reporting and analysis of user and authorization information.

It supports:

- **User reports**
- **Role reports**
- **Authorization reports**
- **Profile reports**
- **Change reports**
- **License reports**

SUIM is widely used by:

- **Security teams**
- **Internal Audit**
- **Compliance**

- **External auditors**
-

Common Reports

- **Users by Role**
 - **Roles by User**
 - **Users with SAP_ALL**
 - **Users with Critical Authorizations**
 - **Locked Users**
 - **Expired Users**
-

Q235. Explain Change Documents.

Executive Answer

Change Documents record modifications made to SAP configuration and master data.

For SAP Security, they provide visibility into:

- **User changes**
- **Role modifications**
- **Authorization updates**
- **Password resets**
- **Administrative activities**

Change documents support:

- **Audit investigations**
 - **Root cause analysis**
 - **Compliance evidence**
-

Q236. Explain STAD.

Executive Answer

STAD (Business Transaction Analysis) provides workload statistics for executed transactions.

Information includes:

- **User**
- **Transaction**
- **Response time**
- **CPU time**
- **Database time**
- **Work process**
- **Execution duration**

Security teams use STAD to:

- **Investigate unusual activity**
- **Support forensic analysis**
- **Identify abnormal workload patterns**

Q237. How do you prepare for an SAP Security Audit?

Architect-level question.

Executive Answer

My preparation includes:

Governance Review

- **Role ownership**
- **Role documentation**
- **SoD review**
- **Mitigation controls**

User Review

- **Dormant users**
 - **Locked users**
 - **SAP_ALL assignments**
 - **Technical users**
-

Logging

- **Verify SM19 configuration**
 - **Validate SM20 logs**
 - **Check log retention**
-

Compliance

- **Periodic access reviews**
 - **Firefighter reviews**
 - **Emergency access logs**
 - **Audit evidence**
-

Technical

- **RFC security**
 - **Background users**
 - **SNC**
 - **Password policies**
-

Q238. Explain SOX Controls for SAP Security.

One of the most common audit questions.

Executive Answer

SAP Security supports several SOX controls.

Examples include:

Preventive Controls

- **Least Privilege**
 - **Segregation of Duties**
 - **Workflow approvals**
 - **Role governance**
-

Detective Controls

- **Audit Logs**
 - **Firefighter Reviews**
 - **Access Reviews**
 - **Exception Reports**
-

Corrective Controls

- **Role redesign**
 - **Access removal**
 - **Mitigation implementation**
-

Q239. Explain IT General Controls (ITGC).

Executive Answer

ITGCs ensure that SAP systems operate securely and reliably.

Key ITGC areas include:

Control Area	Example
User Access	Joiner/Mover/Leaver
Change Management	Transport approvals
Operations	Background jobs
Backup & Recovery	Disaster recovery

Control Area	Example
Monitoring	Security logs
Incident Management	Production support

SAP Security contributes primarily to User Access Management and Monitoring.

Q240. What is Continuous Monitoring?

Executive Answer

Continuous Monitoring is the ongoing review of security events rather than relying solely on periodic audits.

Examples include:

- **Daily SAP_ALL review**
- **Firefighter usage**
- **Failed logon monitoring**
- **High-risk role assignments**
- **Dormant users**
- **Critical transaction execution**

Continuous monitoring allows organizations to detect issues quickly instead of waiting for quarterly or annual audits.

Q241. Production Investigation Scenario

Interviewer

"An auditor informs you that a terminated employee logged into SAP last week. How would you investigate?"

Executive Answer

I would treat this as a high-priority security incident.

1. **Confirm the employee's termination date with HR.**

2. Verify whether the SAP account should have been disabled.
3. Review SM20 to identify the logon details, including timestamp, client, terminal or source system if available.
4. Check SU01 for the user's status, validity dates, and recent changes.
5. Review any SAP IDM or HR integration logs to determine whether the de-provisioning process failed.
6. Identify any activities performed during the session and assess business impact.
7. Immediately lock the account if still active.
8. Perform a root cause analysis and implement corrective actions to prevent recurrence.

Q242. Real Manufacturing Scenario

Interviewer

"Internal Audit asks for evidence showing who modified production planning roles during the last six months. How would you provide it?"

Executive Answer

I would gather evidence from multiple sources:

1. Review transport records to identify security transports affecting production planning roles.
2. Extract role change history and compare role versions.
3. Use change documents where applicable to identify who modified the roles and when.
4. Review approval records from the organization's change management process.
5. If SAP GRC BRM is used, include workflow approvals and version history.
6. Present the evidence in a structured report showing the role name, change date, change owner, approval information, and transport details.

This provides auditors with complete traceability from request through implementation.

Q243. Executive Interview Question

Interviewer

"If you became SAP Security Lead tomorrow, what security KPIs would you present to the CIO every month?"

Executive Answer

I would focus on KPIs that reflect both operational performance and governance:

KPI	Business Value
Total Active Users	Identity management health
Dormant Accounts	Security hygiene
SAP_ALL Users	Privileged access monitoring
High SoD Risks	Governance effectiveness
Open Mitigations	Risk management
Firefighter Usage	Emergency access oversight
Average Provisioning Time	Operational efficiency
Failed Logon Attempts	Threat monitoring
RFC Technical Accounts	Technical risk visibility
Overdue Access Reviews	Compliance status
Role Growth Trend	Role governance
Critical Audit Findings	Executive risk tracking

These metrics give leadership visibility into the organization's security posture and support informed risk management decisions.

Rapid-Fire Questions

Which transaction configures the Security Audit Log?

Answer: SM19

Which transaction displays Security Audit Logs?

Answer: SM20

Which transaction provides User Information reports?

Answer: SUIM

Which transaction provides workload statistics?

Answer: STAD

Which transaction displays authorization failures?

Answer: SU53 (current user's last failed check) or STAUTHTRACE (detailed tracing).

Which report is commonly used for audit evidence related to users and roles?

Answer: SUIM

Architect's Insight

A common interview mistake is to describe audit as a one-time event.

A stronger perspective is:

"Audit readiness should be continuous, not seasonal. If governance processes, monitoring, role reviews, and logging are functioning correctly throughout the year, audits become a validation exercise rather than a recovery effort."

That mindset is exactly what senior managers and architects look for.

Chapter Summary

You should now be comfortable discussing:

- **Security Audit Log**
- **SM19**
- **SM20**

- **SUIM**
 - **STAD**
 - **Change Documents**
 - **SOX controls**
 - **ITGC controls**
 - **Continuous monitoring**
 - **Audit preparation**
 - **Security investigations**
 - **Executive reporting**
-

Next Chapter – SAP Security Performance, Hardening & Best Practices

This chapter will cover:

- **SAP Security Hardening**
- **Password Policies**
- **Client Security**
- **Profile Parameters**
- **Kernel Security**
- **Secure RFC configuration**
- **SAP Notes and Security Patch Day**
- **Vulnerability Management**
- **Security Baseline Reviews**
- **Performance optimization**
- **Security architecture best practices**
- **Executive and architect-level interview scenarios**

This is one of the final advanced SAP Security sections and is commonly discussed in architect, lead consultant, and security governance interviews.